

EU Cyber Resilience Act (CRA) Compliance Services

Strategic Action Framework for JICSS and Akatsuki

Kyoto Infrastructure Security Initiative

Introduction: CRA Disclosure Obligations and Assessment Requirements

Disclosure Obligations: First Line of Compliance

The EU Cyber Resilience Act (CRA), which entered into force on December 10, 2024, establishes **two distinct but complementary compliance tracks**: ongoing disclosure obligations and conformity assessment requirements. Understanding this distinction is critical for planning compliance strategies.

Primary Obligation: Vulnerability and Incident Reporting (Article 14)

Effective Date: September 11, 2026 (21 months after entry into force)

Who Must Comply: All manufacturers of +s placed on the EU market, regardless of product category

Disclosure Requirements:

1. Active Exploitation Notification (Article 14.1)

- **Timeline:** Within 24 hours of awareness
- **Recipient:** ENISA (European Union Agency for Cybersecurity) and the national CSIRT (Computer Security Incident Response Team)
- **Trigger:** Actively exploited vulnerability OR cybersecurity incident having impact on security
- **Content:** Early warning notification with available details

2. Detailed Incident Report (Article 14.2)

- **Timeline:** Within 72 hours of notification (96 hours total from awareness)
- **Content:** Severity assessment, impact description, affected products, exploitability analysis, mitigation measures

- **Updates:** Without undue delay when new information becomes available

3. Final Report (Article 14.3)

- **Timeline:** Within 14 days of incident notification
- **Content:** Detailed incident description, exploit methodology, severity and impact, number of affected products, mitigation measures taken

4. Severe Incident Notification to End Users (Article 14.4)

- **Timeline:** Without undue delay
- **Condition:** When incident is severe and no mitigation available
- **Method:** Public announcement or direct notification

Penalties for Non-Compliance:

- Up to €15 million OR 2.5% of total worldwide annual turnover (whichever is higher)
- Article 64 enforcement provisions

Implementation Status and Evolution:

Current State (as of December 2025):

- ENISA is developing the single reporting platform for manufacturers (target: operational by September 2026)
- Member States designating national CSIRTs as reporting recipients
- Format and technical specifications for reports under development through Commission implementing acts (expected Q1-Q2 2026)

Expected Evolution:

- **Q2 2026:** Commission implementing act defining standardized reporting formats, severity classification schemas, and information elements required
- **Q3 2026:** ENISA single reporting platform goes live with integration to national CSIRTs
- **2027-2028:** Potential expansion of reporting scope based on first-year operational experience; possible delegated acts adjusting timelines for specific product categories

Vulnerability Handling Beyond Reporting (Annex I, Section 2):

In addition to incident reporting, manufacturers have **ongoing obligations** for vulnerability management:

- Establish coordinated vulnerability disclosure policy (Annex I, Section 2.5)
- Provide contact address for vulnerability reporting (Annex I, Section 2.6)

- Publicly disclose fixed vulnerabilities with mitigation guidance (Annex I, Section 2.4)
- Ensure security updates distributed without delay and free of charge (Annex I, Section 2.8)

These obligations apply **throughout the support period** declared by the manufacturer (Article 13.6).

Conformity Assessment Requirements: Pre-Market Obligations

Separate from ongoing disclosure obligations, manufacturers must complete conformity assessment **before placing products on the market**. The CRA establishes a risk-based, three-tier system:

Understanding the CRA Conformity Assessment Framework

Stage 1: Self-Assessment (Default Category)

Approximately 90% of products with digital elements fall under this default category. Manufacturers must:

- Conduct internal risk assessments
- Implement essential cybersecurity requirements per Annex I
- Create technical documentation
- Draft EU Declaration of Conformity
- Affix CE marking

Resources Required:

- Internal cybersecurity expertise
- Documentation systems
- Risk assessment frameworks
- Access to harmonized standards

Stage 2: Third-Party Assessment - Optional (Important Products - Class I)

For important products (e.g., operating systems, anti-virus, routers), manufacturers can choose:

- **Option A:** Self-assessment if applying harmonized standards, common specifications, or EU cybersecurity certification schemes
- **Option B:** Third-party conformity assessment (Modules B+C or H) if not fully applying harmonized standards

Resources Required:

- Engagement with Notified Bodies
- Enhanced technical documentation
- Verification testing infrastructure
- Standards compliance evidence

Stage 3: Mandatory Third-Party Assessment (Critical Products - Class II)

Critical products (e.g., smart cards, secure elements, smart meter gateways, firewalls, hypervisors) always require third-party assessment regardless of standards application.

Resources Required:

- Contracted Notified Body services
- Comprehensive testing facilities
- Advanced security validation capabilities
- Ongoing compliance monitoring

Registration and Accreditation Framework

For Manufacturers:

- No pre-registration required, but must maintain technical documentation
- Obligation to report vulnerabilities (from September 11, 2026)
- Must designate conformity assessment procedures before market placement

For Service Providers (JICSS/Akatsuki): To offer comprehensive CRA compliance services, organizations must:

1. Establish testing laboratories with appropriate equipment
2. Obtain recognition as conformity assessment bodies (if offering third-party assessments)
3. Gain notification by Member State authorities
4. Maintain competence through national accreditation bodies
5. Register on the NANDO website once notified

Breakout of Work for JICSS and Akatsuki

Division of Responsibilities

Critical Distinction: Security Assurance vs. Vulnerability Discovery

It is essential to understand that CRA compliance involves **two functionally distinct activities**:

Security Assurance and Assessment Functions:

- Execute defined test protocols against known security requirements (CRA Annex I)
- Apply standardized testing frameworks (e.g., ISO/IEC 15408, IEC 62443, ETSI EN 303 645)
- Generate audit-quality documentation demonstrating conformity
- Produce evidence packages for notified body review
- Focus: **Verification against established criteria**

Vulnerability Discovery and Disclosure Functions:

- Active search for unknown security weaknesses (penetration testing, fuzzing, reverse engineering)
- Bug bounty programs incentivizing external researcher participation
- Coordinated vulnerability disclosure (CVD) process management
- Incident response and remediation support
- Focus: **Finding previously unknown vulnerabilities**

While both are necessary for comprehensive cybersecurity, **only assurance/assessment functions directly support conformity assessment** (pre-market). Vulnerability discovery primarily supports **ongoing disclosure obligations** (post-market, Article 14).

JICSS (Japan Institute for Cybersecurity Solutions and Standards)

Primary Role: Policy Development, Assessment Framework Design, and International Coordination

Core Functions:

1. Standards Translation and Assessment Framework Development

- Map CRA essential requirements (Annex I) to existing cybersecurity standards
- Develop conformity assessment protocols combining policy requirements with technical test specifications
- Create audit-friendly documentation templates and evidence packaging formats
- Facilitate dialogue between Japanese industry and EU standardization bodies (CEN-CENELC, ETSI)
- **Deliverable Example:** "CRA Annex I.1 (Secure by Default) Assessment Protocol: Test Cases, Evidence Requirements, and Documentation Format"

2. Policy-Led Technical Framework Design

- Define security requirement verification methodologies (what to test, not how to exploit)

- Establish conformity evidence standards for technical documentation (Article 13.12)
- Develop risk assessment frameworks complying with Article 13.2 requirements
- Create traceability matrices linking test results to specific CRA essential requirements
- **Key Output:** Audit-ready assessment packages that notified bodies can efficiently review

3. Disclosure Process Architecture

- Design vulnerability disclosure policy templates (Annex I, Section 2.5)
- Establish incident reporting workflow procedures aligned with Article 14 timelines
- Create integration frameworks between vulnerability discovery outputs and disclosure obligations
- Develop coordination mechanisms with ENISA/CSIRT reporting systems
- **Integration Point:** Bridge between Akatsuki's vulnerability discovery function and manufacturer reporting obligations

4. Policy Research and Advisory

- Monitor EU regulatory developments (delegated acts, implementing regulations, CRA Expert Group outcomes)
- Provide strategic guidance to Japanese manufacturers on compliance pathways
- Develop position papers on Japan-EU cybersecurity cooperation
- Track evolution of harmonized standards and common specifications

5. Education and Capacity Building

- Design executive-level training programs on CRA governance and compliance strategy
- Create awareness campaigns for Japanese industry
- Develop educational materials bridging EU and Japanese regulatory contexts
- Train internal audit teams on CRA conformity assessment procedures

6. International Liaison and Regulatory Coordination

- Represent Japanese interests in CRA Expert Group discussions (observer capacity)
 - Coordinate with European accreditation bodies (EA) and notifying authorities
 - Facilitate bilateral dialogue on mutual recognition frameworks
 - Engage with Japanese regulatory authorities (METI, NISC, MIC) on domestic implementation
-

Akatsuki (一般社団法人AKATSUKI)

Primary Role: Technical Testing Execution, Vulnerability Discovery, and Practical Training

Core Functions:

1. Conformity Assessment Testing Services (SHADOW Platform)

Function A: Structured Security Assurance Testing

- Execute defined test protocols from JICSS-developed assessment frameworks
- Apply standardized testing methodologies (ISO/IEC 15408 evaluation, IEC 62443-4-2 component requirements testing)
- Conduct requirements verification testing against CRA Annex I essential requirements
- Generate structured test reports in audit-friendly formats
- **Output:** Evidence packages supporting EU Declaration of Conformity (Article 28)
- **Client:** Manufacturers preparing for self-assessment or notified body submission

Function B: Vulnerability Discovery and Penetration Testing

- Perform offensive security assessments seeking unknown vulnerabilities
- Conduct fuzzing, reverse engineering, and exploitation research
- Execute penetration testing and red team exercises
- Identify zero-day vulnerabilities in products and systems
- **Output:** Vulnerability reports requiring disclosure under Article 14 obligations
- **Client:** Manufacturers fulfilling ongoing vulnerability management obligations

Critical Distinction:

- Function A produces **conformity evidence** for pre-market assessment
- Function B produces **vulnerability intelligence** for post-market disclosure
- Both utilize SHADOW infrastructure but serve different compliance purposes

2. Testing Infrastructure Operations

- Operate verification laboratories in Kyoto (Keihanna Science City KICK facility, Kyoto Research Park)
- Provide remote access security testing for hardware and software products
- Maintain test equipment inventory covering OT/IoT devices (automotive components, industrial control systems, smart agriculture sensors, medical IoT)
- Develop repeatable testing methodologies enabling consistent results
- Ensure test environment security and confidentiality for proprietary products

3. Practical Training and Certification

Track A: Conformity Assessment Professional Training

- Train engineers on executing standardized security testing protocols
- Develop competency in audit documentation and evidence packaging
- Provide ISO/IEC 17025 (testing laboratory competence) awareness training
- Focus: **Systematic verification against known requirements**

Track B: Ethical Hacker and Security Researcher Training

- Deliver hands-on offensive security training using real equipment
- Train white hat hackers on vulnerability discovery techniques
- Develop coordinated vulnerability disclosure competencies
- Provide CSIRT/PSIRT training for incident response
- Focus: **Discovery of unknown security weaknesses**

4. Vulnerability Disclosure Program Management

- Establish coordinated vulnerability disclosure (CVD) programs for manufacturer clients
- Connect with international bug bounty platforms (HackerOne, Bugcrowd, Synack)
- Create reward frameworks for security researchers
- Manage vulnerability intake, triage, and remediation tracking
- Support manufacturer compliance with Article 14 reporting timelines
- **Service Integration:** Outputs feed into JICSS-designed disclosure processes

5. Pre-Market Readiness Assessment

- Conduct gap analysis against CRA essential requirements before product launch
 - Identify potential non-conformities requiring remediation
 - Validate security update mechanisms (Annex I, Section 2.7)
 - Assess supply chain security controls (software bill of materials verification)
 - **Timing:** Occurs before formal conformity assessment to reduce assessment failure risk
-

Registration Pathways for Akatsuki to Perform Compliance Functions

Current Status and Options Analysis

Akatsuki currently operates as a **testing service provider** without EU regulatory status. To formally support CRA conformity assessment, several pathways exist, each with distinct requirements, timelines, and capabilities:

Pathway 1: Testing Laboratory (No Regulatory Status)

Current Akatsuki Position

Capabilities:

- Conduct security testing for manufacturers preparing conformity assessments
- Generate technical test reports as supporting evidence
- Provide gap analysis and readiness assessments
- Support vulnerability discovery for Article 14 disclosure obligations

Limitations:

- Cannot issue conformity certificates or declarations
- Test reports do not automatically confer presumption of conformity
- Manufacturers remain fully responsible for conformity assessment
- No regulatory recognition under CRA framework

Registration Requirements:

- **None required** for commercial testing services
- Recommended: ISO/IEC 17025 accreditation (testing laboratory competence) for credibility
- **Accreditation Body (Japan):** Japan Accreditation Board (JAB) or International Accreditation Japan (IAJapan)
- **Timeline:** 12-18 months for ISO/IEC 17025 accreditation

Value Proposition:

- Low barrier to entry (already operational)
- Supports self-assessment pathway (default products and Class I with harmonized standards)
- Provides vulnerability discovery services for ongoing compliance

Recommendation: Pursue ISO/IEC 17025 accreditation immediately to enhance credibility while exploring pathways 2-4

Pathway 2: EU Notified Body (Third-Party Conformity Assessment Authority)

Highest Regulatory Status - Enables Full-Service Offerings

Capabilities:

- Conduct conformity assessment for Class I important products (Modules B+C or H)
- Conduct conformity assessment for Class II critical products (mandatory third-party)
- Issue EU-type examination certificates (Module B)
- Perform production quality assurance surveillance (Module C) or full quality assurance (Module H)
- Certificates issued provide presumption of conformity

Registration Requirements:

Step 1: Conformity Assessment Body (CAB) Accreditation

- Demonstrate technical competence per ISO/IEC 17065 (product certification bodies)
- Establish quality management system
- Demonstrate competence in relevant CRA product categories (Implementing Regulation EU 2025/2392)
- Accreditation by national accreditation body

Step 2: Notification by Member State

- Application to Member State notifying authority
- Assessment of competence, independence, and impartiality
- Review by European Commission and other Member States (objection period)
- Publication on NANDO (New Approach Notified and Designated Organisations) database

Geographic Limitation Challenge: Akatsuki is based in **Japan**, not an EU Member State. EU notified bodies must be:

- Established within EU territory (Article 34.1 CRA)
- Notified by an EU Member State notifying authority
- Subject to EU Member State oversight

Possible Solutions:

Option A: Establish EU Subsidiary Entity

- Create Akatsuki Europe GmbH/SAS/Ltd in EU Member State (e.g., Germany, France, Netherlands)
- Transfer or replicate testing infrastructure to EU facility
- Hire EU-based personnel with appropriate qualifications
- Seek accreditation and notification in that Member State
- **Timeline:** 3-5 years (entity formation, infrastructure, accreditation, notification)
- **Investment:** €5-10 million (facility, equipment, personnel, accreditation costs)

Option B: Joint Venture with Existing EU CAB

- Partner with established EU conformity assessment body
- Akatsuki provides technical expertise and testing infrastructure (remote access)
- EU partner holds notified body status and issues certificates
- Revenue sharing arrangement
- **Timeline:** 12-24 months (partnership negotiation, operational integration)
- **Investment:** Lower than Option A, primarily partnership structuring costs

Recommendation: Option B (Joint Venture) is most practical for 2025-2027 timeframe. Begin discussions with European CABs specializing in cybersecurity or industrial products.

Target Partner Profile:

- Existing notified body under machinery, radio equipment, or cybersecurity schemes
- Interested in expanding to CRA product portfolio
- Willingness to leverage remote testing capabilities
- Examples: TÜV SÜD, TÜV Rheinland, BSI Group, SGS, Bureau Veritas, DEKRA

Pathway 3: Recognized Testing Laboratory by EU Notified Body

Pragmatic Near-Term Solution

Model:

- Akatsuki gains recognition as **subcontractor testing laboratory** for EU notified body
- Notified body retains regulatory responsibility and issues certificates
- Akatsuki conducts technical testing per notified body protocols
- Test reports feed into notified body conformity assessment

Requirements:

- ISO/IEC 17025 accreditation (testing competence)
- Contractual agreement with EU notified body
- Compliance with notified body quality requirements
- Periodic audits by notified body
- May require witness testing by notified body staff

Capabilities:

- Provide testing services supporting Class I and Class II conformity assessments
- Leverage SHADOW infrastructure for official assessments
- Generate test reports accepted by notified body

Limitations:

- Cannot issue certificates independently
- Notified body retains final authority
- Revenue shared with notified body partner

Registration Process:

1. Achieve ISO/IEC 17025 accreditation (12-18 months)
2. Approach EU notified bodies seeking testing partners
3. Negotiate subcontractor agreement
4. Complete notified body qualification process (6-12 months)
5. Begin accepting testing projects

Timeline: 18-30 months total

Recommendation: Pursue in parallel with Pathway 2, Option B. Provides revenue stream while joint venture is negotiated.

Pathway 4: EU Cybersecurity Certification Scheme Testing Laboratory (EUCC/Future CRA-Specific Schemes)

Emerging Opportunity

Background:

- Article 27.8 CRA allows European cybersecurity certification schemes (Regulation EU 2019/881) to provide presumption of conformity

- EUCC (EU Common Criteria) scheme adopted (Implementing Regulation EU 2024/482)
- ENISA developing potential CRA-specific certification schemes

Model:

- Akatsuki becomes accredited ITSEF (IT Security Evaluation Facility) under EUCC or future CRA scheme
- Conducts security evaluations resulting in certificates providing CRA presumption of conformity
- Requires evaluation assurance level "substantial" or higher (Article 27.9)

Requirements:

- ISO/IEC 17025 accreditation for security testing
- Scheme-specific accreditation (e.g., Common Criteria Recognition Arrangement for EUCC)
- Technical competence in evaluation methodology (Common Criteria, SESIP, etc.)

Current Status:

- EUCC pilot projects underway (kicked off October 2025)
- Commission delegated act specifying EUCC-CRA interplay expected 2026
- Unclear if/when fully replaces notified body pathway

Timeline: Uncertain - scheme details still under development

Recommendation: Monitor developments but do not pursue as primary pathway until delegated acts clarify scope and mutual recognition provisions.

Recommended Strategy for Akatsuki: Phased Approach

Phase 1 (2025): Immediate Actions

1. **Initiate ISO/IEC 17025 accreditation process** with Japan Accreditation Board
 - Scope: Security testing for IoT, OT, embedded systems
 - Target completion: Q4 2025
2. **Identify 3-5 EU notified body partner candidates** (Pathway 2, Option B and Pathway 3)
3. **Begin discussions** with potential joint venture partners
4. **Continue operating as testing service provider** supporting self-assessment customers

Phase 2 (2026): Establish European Presence

1. **Complete ISO/IEC 17025 accreditation** (Q1 2026)
2. **Finalize partnership agreement** with EU notified body (Q2-Q3 2026)
 - Option preference: Joint venture (Pathway 2, Option B)
 - Fallback: Recognized testing lab (Pathway 3)
3. **Establish operational protocols** for remote testing acceptance by notified body partner
4. **Begin accepting conformity assessment projects** for Class I and Class II products (Q4 2026 target)

Phase 3 (2027-2028): Regulatory Status Enhancement

1. **Evaluate EU subsidiary formation** (Pathway 2, Option A) if demand justifies investment
 2. **Monitor EUCC and CRA certification scheme** developments (Pathway 4)
 3. **Expand notified body partnership** to additional product categories as Implementing Regulation EU 2025/2392 details emerge
 4. **Consider application for Japan-based testing facility recognition** under potential Japan-EU mutual recognition agreement (if negotiated)
-

Third-Party Coordination Recommendations

To deliver comprehensive CRA compliance services, Akatsuki should establish coordination agreements with:

European Notified Bodies (Priority)

- **TÜV SÜD** (Germany): Strong in industrial automation, automotive
- **TÜV Rheinland** (Germany): Cybersecurity and IoT expertise
- **BSI Group** (UK/Netherlands): Product certification, supply chain security
- **DEKRA** (Germany): Automotive and industrial products
- **SGS** (Switzerland/Multi-country): Global reach, multiple product sectors

Coordination Model:

- Joint venture for CRA notified body services (preferred)
- Subcontractor testing laboratory agreement (alternative)
- Revenue share: typically 60-70% to testing lab, 30-40% to notified body for certification authority

Japanese Regulatory Authorities

- **Ministry of Economy, Trade and Industry (METI)**: Industrial product oversight, international standards coordination

- **National center of Incident readiness and Strategy for Cybersecurity (NISC):** Cybersecurity policy coordination
- **Ministry of Internal Affairs and Communications (MIC):** Telecommunications and IoT device regulation
- **Japan Accreditation Board (JAB):** National accreditation body for ISO/IEC 17025

Coordination Purpose:

- Align Akatsuki services with Japanese government export support initiatives
- Facilitate information sharing on EU regulatory developments
- Explore potential for Japan-EU mutual recognition agreements

International Accreditation Bodies

- **European co-operation for Accreditation (EA):** Umbrella organization for EU national accreditation bodies
- **International Laboratory Accreditation Cooperation (ILAC):** Global mutual recognition framework
- **International Accreditation Forum (IAF):** Mutual recognition for certification bodies

Coordination Purpose:

- Ensure Akatsuki's ISO/IEC 17025 accreditation recognized in EU
- Stay informed on accreditation requirement changes for CRA
- Participate in technical committees developing testing standards

European Standardization Organizations

- **CEN-CENELC:** Developing harmonized standards for CRA
- **ETSI (European Telecommunications Standards Institute):** Cybersecurity standards (e.g., ETSI EN 303 645 for IoT)

Coordination Purpose:

- Influence development of harmonized standards to reflect OT security realities
- Early access to draft standards for testing protocol development
- Ensure JICSS-Akatsuki methodologies align with emerging EU standards

Bug Bounty Platforms (For Vulnerability Discovery Function)

- **HackerOne, Bugcrowd, Synack** (Primary platforms)
- **YesWeHack** (European-based platform)

Coordination Purpose:

- Extend vulnerability discovery capacity beyond Akatsuki staff

- Access global security researcher community
- Support manufacturer Article 14 disclosure obligations

Functional Separation: Bug bounty coordination supports **post-market vulnerability management**, not **pre-market conformity assessment**

京都現場インフラ・セキュリティ&データ連携協議会 (Convening Function)

Strategic Positioning

The Kyoto Infrastructure Security Council serves as the **central coordinating mechanism** that unifies JICSS's policy expertise with Akatsuki's technical capabilities to deliver comprehensive CRA compliance services. As a local government-led initiative with Kyoto Prefecture as the principal body, it provides neutral, public-interest focused governance.

Core Convening Functions

1. Multi-Stakeholder Coordination Platform

The Council brings together:

- **Public Sector:** Kyoto Prefecture, municipalities, national government liaison
- **Industry:** Manufacturing companies, automotive, agriculture/food, medical equipment producers
- **Technical Infrastructure:** Telecommunications, cloud, data center, security companies
- **Academia:** Universities, research institutes, technical colleges
- **Financial:** Banking institutions, investment organizations
- **International:** Overseas cybersecurity professionals, ethical hacker communities

Governance Structure:

- **General Assembly:** All-member decision-making body
- **Steering Committee:** Policy deliberation (Kyoto Prefecture, key private sector, academic institutions, observer governments)
- **Subcommittees:**
 - Manufacturing and OT Security
 - Agriculture and Food Infrastructure
 - Medical and Healthcare
 - Human Resource Development and International Collaboration
 - Social Infrastructure Collaboration with Other Local Governments

2. Standards and Compliance Services Integration

Pre-Market Services (Self-Assessment Support):

- Risk assessment workshops facilitated by JICSS expertise
- Gap analysis against CRA essential requirements
- Technical documentation review using Akatsuki validation frameworks
- Harmonized standards application guidance

Testing and Verification Services (Third-Party Preparation):

- Access to SHADOW platform for pre-assessment testing
- Remote penetration testing and vulnerability scanning
- OT/IoT security validation aligned with CRA Annex I requirements
- Test report generation for Notified Body submissions

Continuous Compliance Services:

- Vulnerability disclosure program management
- Security update validation and distribution testing
- Incident response capability assessment
- Supply chain security auditing

3. International Talent Mobilization

Visa Special Zone Development: The Council is examining frameworks to continuously invite world-class ethical hackers and security engineers to Kyoto through:

- National Strategic Special Zones coordination
- Digital Garden Health Special Zone alignment
- Cybersecurity personnel residence status development
- Dialogue with national government and relevant ministries

Benefits for CRA Compliance Services:

- Access to international best practices in security testing
- Training from practitioners experienced in EU certification
- Cross-cultural teams combining Japanese manufacturing knowledge with European regulatory expertise
- Rapid skill transfer to domestic workforce

4. Executive and Management Education

Governance Enhancement Programs:

- Risk awareness training for executives, directors, and department heads

- Investment decision-making frameworks for cybersecurity
- Incident response decision-making exercises (tabletop simulations)
- Board-level reporting format standardization

Sectoral Integration:

- Roundtables linking manufacturing, agriculture, and healthcare management challenges with cybersecurity/data governance
 - Development of "Kyoto Model" cyber governance checklists
 - Executive study sessions on regulatory compliance
-

Action Items: Kyoto Infrastructure Security Council

Immediate Actions (Q1-Q2 2025)

Action 1: Establish Preparatory Committee

Owner: Kyoto Prefecture (Lead Secretariat)

Support: 8M Group (AKATSUKI, JICSS, QuantumMesh)

Timeline: Fiscal 2025

Deliverables:

- Draft Council regulations and governance documents
- Identify founding member organizations (25+ initial members target)
- Secure prefecture budget allocation for secretariat operations
- Establish working group structure

CRA Alignment: Creates organizational foundation to deliver compliance services

Action 2: Operationalize SHADOW Testing Platform

Owner: Akatsuki

Support: Kyoto Prefecture, Manufacturing sector partners

Timeline: February 2026 full operation

Deliverables:

- Complete laboratory setup at KICK facility
- Establish remote access protocols for distributed testing

Highly Confidential - Proprietary to Miller Enterprises, K.K.

- Onboard initial manufacturing companies (automotive components, IoT devices)
- Develop testing protocols mapped to CRA essential requirements (Annex I)

CRA Alignment: Provides technical infrastructure for pre-market security validation

Action 3: Map CRA Requirements to Japanese Standards

Owner: JICSS

Support: CEN-CENELC liaison, ENISA consultation

Timeline: Q2 2025

Deliverables:

- Comparative analysis: CRA Annex I vs. Japanese cybersecurity standards
- Gap identification report highlighting areas requiring new guidance
- Translation of key CRA terminology into Japanese technical vocabulary
- Preliminary harmonized standards application guide for Japanese manufacturers

CRA Alignment: Enables Japanese companies to understand compliance pathways using familiar frameworks

Action 4: Launch Pilot Compliance Assessment Program

Owner: Kyoto Council (coordinated by JICSS and Akatsuki)

Participants: 3-5 manufacturing companies (pilot partners)

Timeline: Q2-Q3 2025

Deliverables:

- Conduct end-to-end compliance readiness assessments
- Generate sample technical documentation packages
- Test SHADOW platform for evidence generation
- Document lessons learned and refine service offerings

CRA Alignment: Validates service model and identifies gaps before regulation fully applies (December 2027)

Medium-Term Actions (Q3 2025 - Q2 2026)

Action 5: Establish International Partnership Network

Owner: JICSS (international liaison function)

Support: Kyoto Prefecture diplomatic channels, JETRO

Timeline: Ongoing through 2025-2026

Deliverables:

- Memoranda of Understanding with European Conformity Assessment Bodies
- Partnership agreements with bug bounty platforms (e.g., HackerOne, Bugcrowd)
- Observer status or information sharing with CRA Expert Group
- Collaboration with ENISA on certification scheme development

CRA Alignment: Positions Japanese services within European compliance ecosystem

Action 6: Develop Sectoral Playbooks

Owner: Council Subcommittees (Manufacturing, Agriculture, Medical)

Support: JICSS (standards), Akatsuki (technical validation)

Timeline: Q4 2025 - Q2 2026

Deliverables:

- Manufacturing Sector CRA Compliance Guide (focus: automotive, industrial robotics)
- Agriculture/Food Sector Guide (focus: smart farming, cold chain IoT)
- Medical Device Sector Guide (focus: connected healthcare equipment)
- Each playbook includes: risk assessment templates, testing checklists, documentation frameworks

CRA Alignment: Translates horizontal CRA requirements into vertical sector-specific guidance

Action 7: Executive Education Program Launch

Owner: Council Human Resource Development Subcommittee

Lead Faculty: JICSS (policy content), Invited international experts

Timeline: Q1 2026 inaugural session

Deliverables:

- 3-day Executive Cybersecurity Governance Program (quarterly offering)

Highly Confidential - Proprietary to Miller Enterprises, K.K.

- Tabletop exercises simulating CRA non-compliance scenarios
- Board reporting template for cybersecurity risk
- Cyber resilience investment decision frameworks

CRA Alignment: Ensures management commitment to compliance, critical for resource allocation

Action 8: White Hat Hacker Training and Certification

Owner: Akatsuki

Support: International CTF champions, bug bounty professionals

Timeline: Q3 2025 pilot cohort, Q1 2026 regular program

Deliverables:

- 12-week intensive bootcamp (40 participants annually)
- Curriculum covering: OT security, hardware hacking, vulnerability research, coordinated disclosure
- Certification program recognized by Council member companies
- Job placement support with manufacturing sector CSIRT/PSIRT teams

CRA Alignment: Builds domestic capacity to support ongoing vulnerability management obligations (CRA Article 14)

Long-Term Strategic Actions (2026-2027)

Action 9: Notified Body Pathway Development

Owner: Council Steering Committee

Support: National government (METI, NISC), EA Japan coordination

Timeline: 2026-2027 preparation for CRA full application

Deliverables:

- Feasibility study: Requirements for Japanese organization to become EU Notified Body
- If feasible: Accreditation application to national accreditation body
- Alternative: Partnership agreements with European Notified Bodies for co-verification
- Establishment of Japan-based testing that European Notified Bodies recognize

CRA Alignment: Enables offering of third-party conformity assessment services for Class I/II products

Action 10: National and International Model Expansion

Owner: Kyoto Prefecture (model dissemination)

Support: JICSS (knowledge transfer), Akatsuki (technical replication)

Timeline: 2026-2028

Deliverables:

- "Kyoto Model" documentation for other prefectures
- Pilot replication in 2-3 other regions (targeting manufacturing hubs: Aichi, Osaka, Fukuoka)
- International promotion at cybersecurity conferences (RSA, Black Hat, DEF CON)
- Collaboration framework with ASEAN nations facing similar compliance challenges

CRA Alignment: Scales Japan's CRA compliance support infrastructure nationally and positions Japan as regional leader

Proposed 2026 KPIs

For JICSS:

- Number of Japanese manufacturers supported with CRA guidance (Target: 200+ by 2027)
- Standards mapping documents published (Target: 10 major standards by end 2025)
- Executive training participants (Target: 500 executives by 2027)
- International partnership agreements executed (Target: 5+ by end 2026)

For Akatsuki:

- Testing projects completed via SHADOW platform (Target: 100+ products by 2027)
- White hat hackers trained and certified (Target: 120 by 2027)
- Vulnerability disclosures processed (Target: 50+ per year by 2027)
- Reduction in average time-to-patch for member companies (Target: <30 days)

For Kyoto Council:

- Member organizations enrolled (Target: 100+ by end 2026)
- Pilot companies successfully achieving CRA readiness (Target: 20+ by 2027)
- Overseas security professionals hosted in Kyoto (Target: 30+ annually by 2027)
- Replication of model in other prefectures (Target: 3+ by 2028)

APPENDIX A: EU Regulatory References

Primary Legislation

Regulation (EU) 2024/2847 - Cyber Resilience Act (CRA)

- **Official Journal Reference:** OJ L, 2024/2847, 10.12.2024
- **Entry into Force:** 10 December 2024
- **Full Application:** 11 December 2027
- **EUR-Lex Permalink:**
<https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R2847>
- **Key Provisions:**
 - Article 13: Obligations of manufacturers
 - Article 14: Reporting obligations for actively exploited vulnerabilities and severe incidents
 - Article 27: Presumption of conformity
 - Article 28: EU declaration of conformity
 - Article 32-33: Conformity assessment procedures
 - Article 34-40: Notified bodies
 - Article 64: Penalties
 - Annex I: Essential cybersecurity requirements
 - Annex III: Important products with digital elements (Class I)
 - Annex IV: Critical products with digital elements (Class II)
 - Annex V: EU declaration of conformity (full format)
 - Annex VI: Simplified EU declaration of conformity
 - Annex VIII: Conformity assessment procedures

Implementing and Delegated Acts

Implementing Regulation (EU) 2025/2392

- **Title:** Technical descriptions of product categories (Annexes III and IV)
- **Adoption Date:** Expected 11 December 2025
- **Purpose:** Clarifies which specific products fall into important (Class I) and critical (Class II) categories
- **Status:** Under comitology procedure (as of October 2025 CRA Expert Group meeting)

Draft Delegated Act on Notification Delays

- **Subject:** Terms and conditions for delaying vulnerability/incident notifications (Article 14.6)
- **Status:** Public consultation closed 13 November 2025
- **Expected Adoption:** 11 December 2025

- **Relevance:** Defines circumstances where manufacturers may delay public disclosure to prevent harm

Draft Delegated Act on European Cybersecurity Certification Schemes (Article 27.9)

- **Subject:** Conditions under which EUCC and future schemes provide CRA presumption of conformity
- **Status:** Under development; ENISA pilot projects ongoing (kicked off October 2025)
- **Expected Timeframe:** 2026
- **Relevance:** May provide alternative pathway to notified body assessment for certain products

Future Implementing Acts on Reporting (Article 14.7)

- **Subject:** Format, information elements, and procedures for vulnerability/incident reporting
- **Expected Timeframe:** Q1-Q2 2026 (before September 11, 2026 reporting obligation effective date)
- **Developing Body:** European Commission in consultation with ENISA and CRA Expert Group

Related EU Cybersecurity Legislation

Regulation (EU) 2019/881 - Cybersecurity Act

- **EUR-Lex:** <https://eur-lex.europa.eu/eli/reg/2019/881/oj>
- **Relevance:** Establishes European cybersecurity certification framework; CRA Article 27.8 allows certified products to claim presumption of conformity
- **Key Provisions:**
 - Article 48: Preparation of candidate schemes by ENISA
 - Article 54: EU cybersecurity certificates

Implementing Regulation (EU) 2024/482 - EUCC Scheme

- **Title:** European Common Criteria based cybersecurity certification scheme (EUCC)
- **Adoption Date:** 8 February 2024
- **EUR-Lex:** https://eur-lex.europa.eu/eli/reg_impl/2024/482/oj
- **Relevance:** First cybersecurity certification scheme potentially providing CRA presumption of conformity (pending Article 27.9 delegated act)

Directive (EU) 2022/2555 - NIS2 Directive

- **Title:** Measures for high common level of cybersecurity across the Union
- **Relevance:** Complementary framework for essential and important entities; creates CSIRT network that receives CRA Article 14 reports

- **Transposition Deadline:** 17 October 2024 (Member States implementing)

Standardization Mandates and References

Regulation (EU) No 1025/2012

- **Title:** European standardisation
- **Relevance:** Legal basis for harmonized standards providing presumption of conformity

CEN-CENELC Standardization Request

- **Subject:** Development of harmonized standards for CRA essential requirements (Annex I)
- **Status:** Standardization mandate under development by European Commission
- **Expected Issuance:** 2025
- **Target Completion:** Before December 11, 2027 (to enable self-assessment using harmonized standards)

ETSI EN 303 645 (v2.1.1)

- **Title:** Cybersecurity for consumer Internet of Things
- **Status:** Published; candidate for CRA harmonization
- **Relevance:** Baseline security provisions for IoT devices

IEC 62443 Series

- **Title:** Industrial communication networks - Network and system security
- **Status:** International standard series; parts being considered for CRA harmonization
- **Relevance:** Critical for OT/ICS security requirements in manufacturing sector

ISO/IEC 15408 Series (Common Criteria)

- **Title:** Information security, cybersecurity and privacy protection - Evaluation criteria for IT security
- **Status:** International standard; basis for EUCC scheme
- **Relevance:** Provides evaluation methodology for Class II critical products

Guidance and Supporting Documents

European Commission CRA FAQ Document

- **Document ID:** 122331
- **URL:** <https://ec.europa.eu/newsroom/dae/redirection/document/122331>
- **Last Updated:** December 2024 (context to CRA entry into force)

ENISA - CRA Requirements Standards Mapping

- **Document:** "Cyber Resilience Act Requirements Standards Mapping" (Joint Research Centre & ENISA Joint Analysis)
- **Publication Code:** EUR 31892 EN
- **ISBN:** 978-92-68-14180-9
- **DOI:** 10.2760/905934
- **Purpose:** Maps each CRA Annex I requirement to existing cybersecurity standards, identifies gaps

European Commission Digital Strategy CRA Page

- **URL:** <https://digital-strategy.ec.europa.eu/en/policies/cyber-resilience-act>
- **Content:** Overview, conformity assessment guidance, Member State roles, standardisation updates

Conformity Assessment Infrastructure

NANDO Database (Notified Bodies)

- **URL:** <https://webgate.ec.europa.eu/single-market-compliance-space/notified-bodies>
- **Purpose:** Official database of notified bodies authorized to conduct CRA conformity assessments
- **Search Filter:** Legislation ID: 167953 (CRA)
- **Note:** Database will populate as Member States notify conformity assessment bodies (from June 2026 onward)

List of Notifying Authorities

- **URL:** <https://webgate.ec.europa.eu/single-market-compliance-space/notified-bodies/notifying-authorities?filter=legislationId:167953>
- **Purpose:** Contact points in each Member State for conformity assessment body notification

EA (European co-operation for Accreditation)

- **URL:** <https://european-accreditation.org/>
- **Role:** Network of national accreditation bodies; develops accreditation requirements for CRA notified bodies
- **Relevance:** Oversees competence assessment of conformity assessment bodies

APPENDIX B: Japanese Functional Actors in CRA Compliance

Government Ministries and Agencies

Ministry of Economy, Trade and Industry (METI) / 経済産業省

- **English:** <https://www.meti.go.jp/english/>
- **Primary Functions:**
 - Industrial policy and export promotion
 - International trade negotiations and regulatory cooperation
 - Oversight of Information-technology Promotion Agency (IPA)
 - Standards development coordination through Japanese Industrial Standards Committee (JISC)
- **CRA Relevance:**
 - Leads Japan-EU regulatory dialogue on product conformity
 - Coordinates support for Japanese manufacturers accessing EU market
 - May negotiate mutual recognition agreements for testing/certification
 - Oversees Industrial Cybersecurity Center of Excellence (ICSCoE) - potential CRA training partner

National center of Incident readiness and Strategy for Cybersecurity (NISC) / 内閣サイバーセキュリティセンター

- **URL:** <https://www.nisc.go.jp/eng/index.html>
- **Primary Functions:**
 - National cybersecurity strategy formulation
 - Coordination of government-wide cybersecurity measures
 - Critical infrastructure protection policy
 - International cybersecurity cooperation
- **CRA Relevance:**
 - Alignment of CRA requirements with Japan's cybersecurity framework
 - Coordination with ENISA and EU CSIRT network
 - Policy guidance on vulnerability disclosure practices
 - Oversight of Cybersecurity Strategic Headquarters

Ministry of Internal Affairs and Communications (MIC) / 総務省

- **English:** <https://www.soumu.go.jp/english/>
- **Primary Functions:**
 - Telecommunications regulation
 - IoT device security standards (Telecommunications Business Act)
 - Operation of National Institute of Information and Communications Technology (NICT)
- **CRA Relevance:**

- Regulatory authority for telecommunications products (overlap with CRA scope)
- IoT Security Guidelines may align with CRA requirements
- NICT operates NOTICE project (IoT device vulnerability scanning)

Ministry of Health, Labour and Welfare (MHLW) / 厚生労働省

- **URL:** <https://www.mhlw.go.jp/english/>
- **Primary Functions:**
 - Medical device regulation (Pharmaceuticals and Medical Devices Act)
 - Healthcare system cybersecurity
- **CRA Relevance:**
 - Medical IoT devices subject to both MHLW and CRA requirements
 - Coordination needed for dual-regulated products
 - Patient safety considerations in vulnerability disclosure

Ministry of Land, Infrastructure, Transport and Tourism (MLIT) / 国土交通省

- **URL:** <https://www.mlit.go.jp/en/>
- **Primary Functions:**
 - Automotive safety regulation (Road Transport Vehicle Act)
 - Connected vehicle standards
 - Smart city infrastructure
- **CRA Relevance:**
 - Automotive components and connected vehicle systems under CRA scope
 - UN-ECE WP.29 cybersecurity regulations alignment
 - Infrastructure IoT security standards

Accreditation and Standards Bodies

Japan Accreditation Board (JAB) / 公益財団法人日本適合性認定協会

- **URL:** <https://www.jab.or.jp/english/>
- **Primary Functions:**
 - National accreditation body for conformity assessment
 - ISO/IEC 17025 accreditation (testing laboratories)
 - ISO/IEC 17065 accreditation (product certification bodies)
 - Member of International Laboratory Accreditation Cooperation (ILAC)
 - Member of International Accreditation Forum (IAF)
- **CRA Relevance:**
 - Accredits testing laboratories like Akatsuki for ISO/IEC 17025
 - Mutual recognition agreements with EA member accreditation bodies
 - Enables international recognition of Japanese testing services
 - **Action Item:** Akatsuki should engage JAB for ISO/IEC 17025 accreditation process

International Accreditation Japan (IAJapan)

- **URL:** <https://www.ia-japan.or.jp/>
- **Primary Functions:**
 - Alternative national accreditation body
 - Focus on management systems and personnel certification
- **CRA Relevance:**
 - Potential alternative to JAB for certain accreditation scopes

Japanese Standards Association (JSA) / 日本規格協会

- **URL:** <https://www.jsa.or.jp/>
- **Primary Functions:**
 - National standards development
 - ISO/IEC standards adoption and translation
 - JIS (Japanese Industrial Standards) secretariat
- **CRA Relevance:**
 - Translates international cybersecurity standards to Japanese
 - Coordinates Japan's positions in ISO/IEC cybersecurity standardization
 - Partner for JICSS standards mapping efforts

Information-technology Promotion Agency (IPA) / 独立行政法人情報処理推進機構

- **URL:** <https://www.ipa.go.jp/en/index.html>
- **Primary Functions:**
 - IT security evaluation and certification (JISEC - Japan IT Security Evaluation and Certification Scheme)
 - Vulnerability coordination (JVN - Japan Vulnerability Notes)
 - Common Criteria certification authority
 - Cybersecurity human resource development
- **CRA Relevance:**
 - JISEC operates Japan's Common Criteria scheme (ISO/IEC 15408)
 - JVN operates coordinated vulnerability disclosure framework
 - Potential coordination with ENISA on EUCC-CRA interplay
 - **Collaboration Opportunity:** JICSS-IPA partnership on vulnerability disclosure best practices

Industry Associations

Japan Electronics and Information Technology Industries Association (JEITA) / 一般社団法人電子情報技術産業協会

- **URL:** <https://www.jeita.or.jp/english/>
- **Membership:** Major electronics and IT manufacturers
- **CRA Relevance:**

- Advocacy for Japanese industry in EU regulatory processes
- Coordination of industry feedback on CRA implementation
- Development of sector-specific compliance guidance

Japan Automobile Manufacturers Association (JAMA) / 一般社団法人日本自動車工業会

- **URL:** <https://www.jama-english.jp/>
- **Membership:** Major automotive manufacturers
- **CRA Relevance:**
 - Automotive components and systems under CRA scope
 - Coordination with UN-ECE WP.29 cybersecurity regulations
 - Industry positions on connected vehicle security requirements

Japan Medical Device Technology Association (JMDA) / 日本医療機器テクノロジー協会

- **URL:** <http://www.jamdit.jp/>
- **Membership:** Medical device manufacturers
- **CRA Relevance:**
 - Connected medical devices subject to CRA
 - Coordination between medical device regulations and cybersecurity requirements
 - Patient safety considerations in security testing

Cybersecurity Research and Response Organizations

JPCERT/CC (Japan Computer Emergency Response Team Coordination Center)

- **URL:** <https://www.jpcert.or.jp/english/>
- **Primary Functions:**
 - National CSIRT coordination
 - Vulnerability information handling
 - Incident response coordination
 - Early warning for cyber threats
- **CRA Relevance:**
 - Coordination point for Article 14 incident reports from Japanese manufacturers
 - Bridge between Japanese manufacturers and ENISA/EU CSIRT network
 - Operates Japan Vulnerability Notes (JVN) database
 - **Critical Partner:** Should be formal liaison in Kyoto Council structure

National Institute of Information and Communications Technology (NICT) / 国立研究開発法人情報通信研究機構

- **URL:** <https://www.nict.go.jp/en/>
- **Primary Functions:**
 - Cybersecurity research
 - NICTER (Network Incident analysis Center for Tactical Emergency Response)

- IoT security research (NOTICE project)
- **CRA Relevance:**
 - Research on IoT vulnerability detection methods
 - Threat intelligence sharing
 - Potential collaboration on testing methodologies

Financial and Investment Organizations

Development Bank of Japan (DBJ) / 株式会社日本政策投資銀行

- **URL:** <https://www.dbj.jp/en/>
- **CRA Relevance:**
 - Financing support for manufacturers investing in CRA compliance infrastructure
 - Evaluation of cybersecurity investment as part of ESG criteria

Organization for Small & Medium Enterprises and Regional Innovation (SMRJ) / 独立行政法人中小企業基盤整備機構

- **URL:** <https://www.smrj.go.jp/english/>
- **CRA Relevance:**
 - Support programs for SMEs accessing international markets
 - Potential subsidies for CRA compliance costs for smaller manufacturers

Regional Government Actors

Kyoto Prefecture / 京都府

- **URL:** <https://www.pref.kyoto.jp/>
- **Role in Kyoto Council:**
 - Lead secretariat and convening authority
 - Budget allocation for council operations
 - Coordination with national government
 - Local SME support programs
- **CRA Relevance:**
 - Local government champion for CRA compliance support
 - Model for other prefectures (Aichi, Osaka, Fukuoka)

Kyoto Prefectural Police Cyber Division / 京都府警察サイバー企画課

- **Role:**
 - Secretariat for "Kyoto Business Cybersecurity Support Network"
 - Monthly meetings on cyberattack trends
 - Liaison with Akatsuki and JICSS
- **CRA Relevance:**
 - Incident information sharing

- Criminal investigation coordination for cyberattacks on manufacturers

Academic and Research Institutions

Kyoto University / 京都大学

- **Academic Center for Computing and Media Studies**
- **Institute for Integrated Cell-Material Sciences (iCeMS)** - IoT research
- **CRA Relevance:** Research partnerships, talent pipeline

Doshisha University / 同志社大学

- **Faculty of Science and Engineering - Department of Information Systems Design**
- **CRA Relevance:** Cybersecurity education, cooperative research

Osaka University / 大阪大学

- **Center for Information and Neural Networks (CiNet)**
- **Cybermedia Center**
- **CRA Relevance:** AI security research, vulnerability analysis methodologies

APPENDIX C: Glossary of Key Terms

CAB (Conformity Assessment Body): Organization that performs conformity assessment services (testing, certification, inspection); must be accredited and notified to become a notified body under CRA.

CRA Expert Group: Commission expert group on cybersecurity of products with digital elements; advises European Commission on CRA implementation; publishes meeting minutes and draft documents.

CSIRT (Computer Security Incident Response Team): Team responsible for receiving, reviewing, and responding to computer security incident reports; designated by Member States as recipients of Article 14 manufacturer reports.

Essential Cybersecurity Requirements: Mandatory security requirements in CRA Annex I that products must meet; organized into: (1) security of properties, (2) vulnerability handling, (3) security updates, (4) security by default.

Harmonized Standard: European standard developed by CEN, CENELC, or ETSI following Commission mandate; compliance creates presumption of conformity with corresponding CRA requirements.

Notified Body: Conformity assessment body designated and notified by a Member State; authorized to conduct third-party conformity assessments for Class I and Class II products.

Notifying Authority: Public authority in each Member State responsible for assessing, designating, and notifying conformity assessment bodies.

Module: Conformity assessment procedure defined in CRA Annex VIII and CRA Article 32-33:

- Module A: Internal control (self-assessment)
- Module B: EU-type examination (design phase assessment by notified body)
- Module C: Conformity to type based on production quality assurance
- Module H: Full quality assurance

Presumption of Conformity: Legal presumption that product meets CRA essential requirements if it complies with harmonized standards, common specifications, or recognized certification schemes.

Product with Digital Elements: Hardware or software product placed on EU market; includes final products and components intended for integration; excludes medical devices, aviation, motor vehicles (separate regulations apply).

Substantial Support Period: Time during which manufacturer provides security updates; must be explicitly communicated to users (CRA Article 13.6).

Vulnerability: Weakness, susceptibility, or flaw in a product that can be exploited to negatively affect the cybersecurity of that product (CRA Article 3.9).